



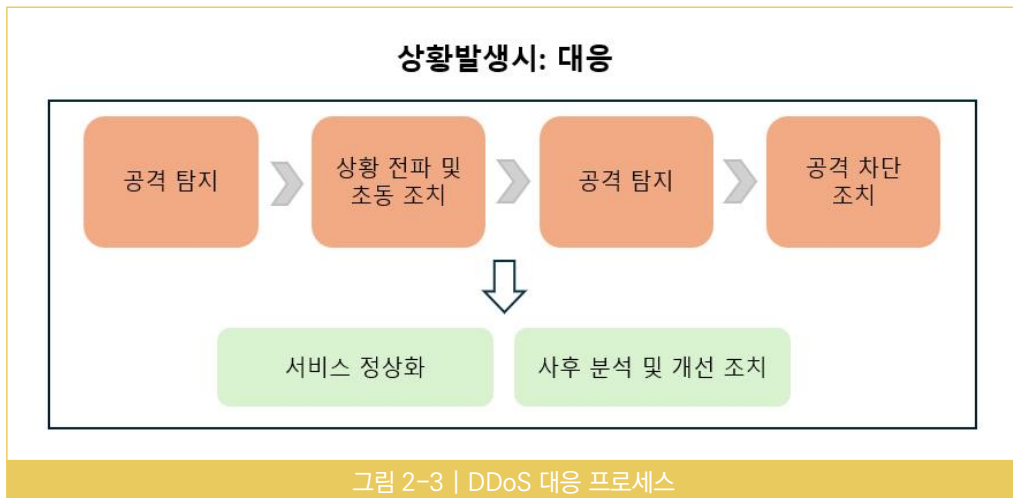
SSDP Amplification	UPnP(Universal Plug and Play) 프로토콜의 일부인 SSDP(Simple Service Discovery Protocol)를 악용합니다. 네트워크 내의 장치들이 서로를 검색하고 통신할 수 있도록 하는 SSDP는 UDP 포트 1900번을 사용하는데, 공격자는 이 포트로 출발지가 위조된 M-SEARCH 요청을 브로드캐스트하여 네트워크 내의 다수 장치로부터 응답을 받아 공격 대상에게 집중시킵니다.
CLDAP Reflection	LDAP(Lightweight Directory Access Protocol)의 UDP 기반 버전인 CLDAP(Connectionless LDAP) 서버를 악용하는 공격입니다. CLDAP 요청에 대한 응답은 요청보다 훨씬 클 수 있어(요청 대비 56~70배 증폭 가능), 효과적인 증폭 공격 벡터로 사용됩니다.
SMURF	공격자가 인터넷 제어 메시지 프로토콜(ICMP) 패킷으로 대상 서버를 폭주시키려고 시도하는 공격입니다. 대상 장치의 스푸핑된 IP 주소를 사용하여 하나 이상의 컴퓨터 네트워크에 요청함으로써 컴퓨터 네트워크는 대상 서버에 응답하여 초기 공격 트래픽을 증폭하고 잠재적으로 대상을 압도하여 액세스할 수 없게 만듭니다.

< DDoS 공격 유형 (출처: CLOUDFLARE/HC3:Analyst Note) >

| 제 5 절 | 대응 방안

DDoS 공격에 효과적으로 대응하기 위해서는 상황 발생 전의 철저한 예방조치, 상황 발생 시 신속한 탐지 및 분석, 그리고 유형별 맞춤형 차단 후 사후 조치가 유기적으로 연계하는 것이 무엇보다 중요하며 이를 위해 대응체계 수립, 차단정책 설정, 가용성 확보 등의 조치가 필요합니다. 상황이 발생했다면 모니터링을 통해 조기에 공격을 인지하고 그 유형을 판단 후 유관기관에도 신고합니다. 신고 후에는 유관기관과 공조하여 대응할 수 있도록 합니다. 공격유형별 차단 조치를 시행하되 방어가 제한되는 상황에서는 서비스 최소화 조치를 실행합니다.

전체적인 대응 프로세스는 아래 그림과 같습니다.



1. DDoS 대응 방안

DDoS 공격이 실제로 발생했을 때는 당황하지 않고 사전에 준비된 절차에 따라 신속하고 침착하게 대응하는 것이 중요합니다.

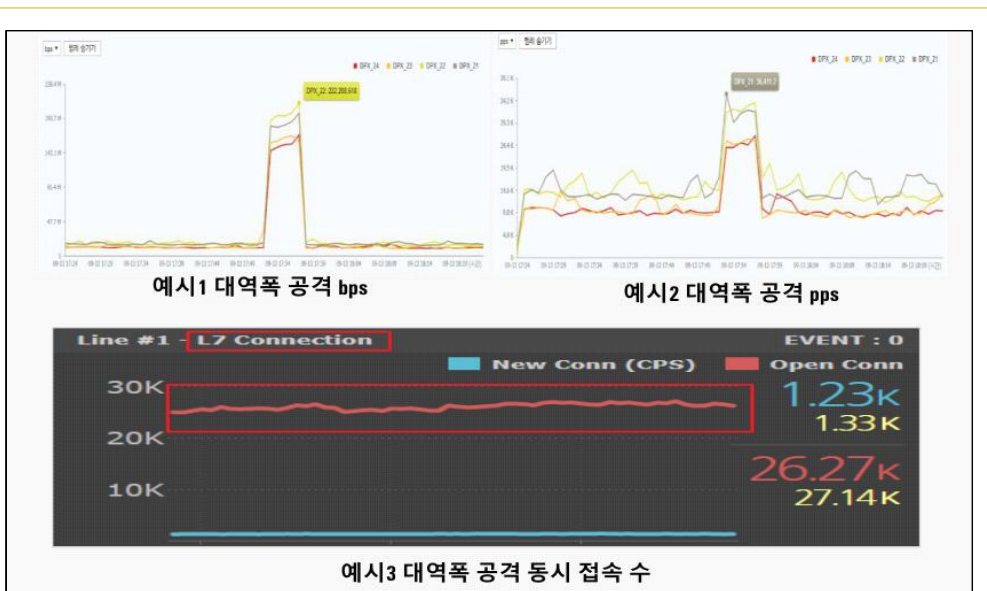
① 서비스 모니터링 강화 및 공격 인지

- 평소 웹사이트나 서비스의 상태(응답 속도, 접속자 수, 서버 자원 사용률 등)를 꾸준히 모니터링하는 것이 중요합니다. 대부분의 보안 장비나 호스팅 서비스에서 기본적인 모니터링 기능을 제공합니다.
- 서비스 속도가 갑자기 느려지거나 접속이 안 되는 현상이 발생하면, 단순 서버 장애인지, 특정 콘텐츠에 대한 정상적인 접속폭주인지, 아니면 DDoS 공격인지 신속하게 파악해야 합니다.
- 네트워크 트래픽 분석 도구(wireshark^[15], tcpdump^[16] 등)나 DDoS 대응 장비, 통합보안관제(SIEM) 시스템 등을 활용하면 공격 여부와 유형을 보다 정확하게 식별하는 데 도움이 될 수 있습니다.

② 공격 유형 판단

DDoS 공격으로 의심되는 상황이 발생하면, 가장 먼저 현재 받고있는 공격의 유형을 파악해야 효과적인 대응이 가능합니다.

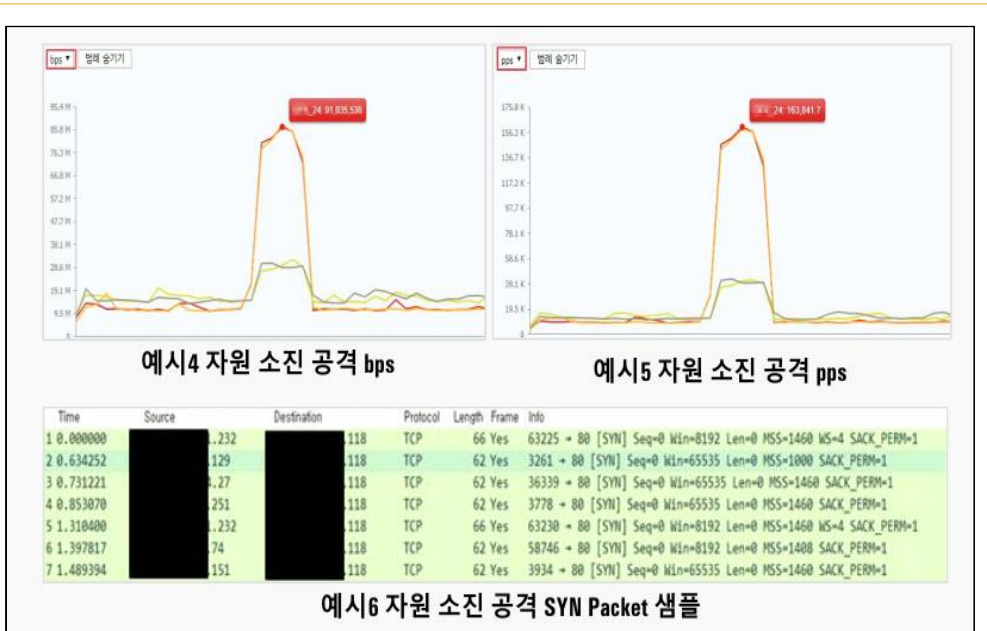
- **(대역폭 소모형 공격 의심)** 평소보다 네트워크 사용량(bps, bits per second)이나 초당 패킷 수(pps, packets per second)는 매우 높지만, 동시 접속자 수는 큰 변화가 없거나 오히려 감소한다면 대역폭 소모형 공격일 가능성이 높습니다.



(출처: KISA DDoS 공격 대응가이드)

그림 2-4 | 대역폭 공격 시 네트워크 상태

- **(자원 소진 공격: 프로토콜/애플리케이션 계층 공격 의심)** 네트워크 사용량(bps)은 크게 높지 않지만, 초당 패킷 수(pps)나 동시 접속자 수가 비정상적으로 급증하고 서버 CPU, 메모리 사용률이 치솟는다면 프로토콜 취약점 공격이나 애플리케이션 계층 공격을 의심해 볼 수 있습니다.



(출처: KISA DDoS 공격 대응가이드)

그림 2-5 | 자원소진 공격 시 네트워크 상태

- 파악된 공격 정보(공격 유형, 공격 시작 시간, 출발지 IP 현황 등)는 사내 관련 부서(IT팀, 경영진 등) 및 외부 협력업체(ISP, 호스팅 업체, 보안 서비스 업체 등)와 신속하게 공유하여 공동 대응 체계를 가동합니다.

③ 유관기관 신고 및 협조 요청

DDoS 공격으로 확인되었거나 의심되는 경우, 즉시 한국인터넷진흥원(KISA) 등 유관기관에 신고하여 기술 지원, 공격 차단 지원, 증거 수집 등 전문가의 도움을 받는 것이 중요합니다.

(신고 방법은 '4.4. 참고 사항'참조)



신고 후에는 유관기관과 긴밀히 협력하여 공격 상황을 공유하고 대응 조치를 함께 진행합니다.

④ 공격 차단 및 완화 조치 실행

- **자체 보안 장비 활용:** 사전에 설정된 방화벽, IPS, WAF 등의 차단 정책을 활성화하거나, 공격 상황에 맞게 새로운 차단 규칙(룰)을 적용합니다. 예를 들어, 특정 IP 대역에서 비정상적인 트래픽이 집중된다면 해당 IP 대역을 우선 차단합니다.
- **DDoS 방어 서비스 활용:** 가입된 DDoS 방어 서비스 업체에 공격 사실을 알리고, 준비된 절차에 따라 트래픽 우회, 필터링 등의 방어 조치를 요청하거나 자동으로 적용되도록 합니다. 클라우드 기반 방어 서비스의 경우, 공격 트래픽을 대규모 분산 네트워크로 흡수하여 정화한 후 정상 트래픽만 전달해 줄 수 있습니다.
- **ISP/호스팅 업체 협조:** 인터넷 회선 제공업체(ISP)나 서버 호스팅 업체에 연락하여 공격 상황을 알리고, 상위 네트워크단에서의 트래픽 차단이나 필터링 지원을 요청합니다.
- **서비스 최소화 및 비상 운영:** 공격 방어가 어려운 상황이거나 피해가 확산될 우려가 있다면, 일시적으로 중요도가 낮은 서비스를 중단하거나, 핵심 서비스만 최소한으로 운영하여 피해를 줄이는 방안도 고려할 수 있습니다.

⑤ 서비스 정상화 확인 및 모니터링 지속

- 공격이 잦아들고 차단 조치가 효과를 발휘하여 서비스가 정상화되면, 모든 기능이 제대로 작동하는지 꼼꼼히 확인합니다.



- 공격이 완전히 종료될 때까지 지속적으로 서비스 상태와 네트워크 트래픽을 모니터링하고, 추가 공격 발생에 대비합니다.

⑥ 사후 분석 및 재발 방지 대책 수립

- 공격이 완전히 종료된 후에는 공격의 원인, 유형, 규모, 피해 상황, 대응 과정 등을 상세히 분석하고 기록으로 남깁니다.
- 분석 결과를 바탕으로 기존 보안 대책의 미비점을 보완하고, 재발 방지를 위한 개선 방안(시스템 설정 변경, 보안 장비 업그레이드, 대응 프로세스 수정 등)을 수립하여 시행합니다.
- 모의훈련 시나리오에 이번 공격 사례를 반영하여 향후 대응 능력을 강화합니다.

2. 참고사항

① DDoS 공격 신고

- DDoS 공격으로 확인되었거나 의심되는 경우 KISA 등 유관기관에 신고를 하면, 전문가들의 지원을 받을 수 있습니다.

※ 근거법령 : 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제48조의 3(침해사고의 신고 등)

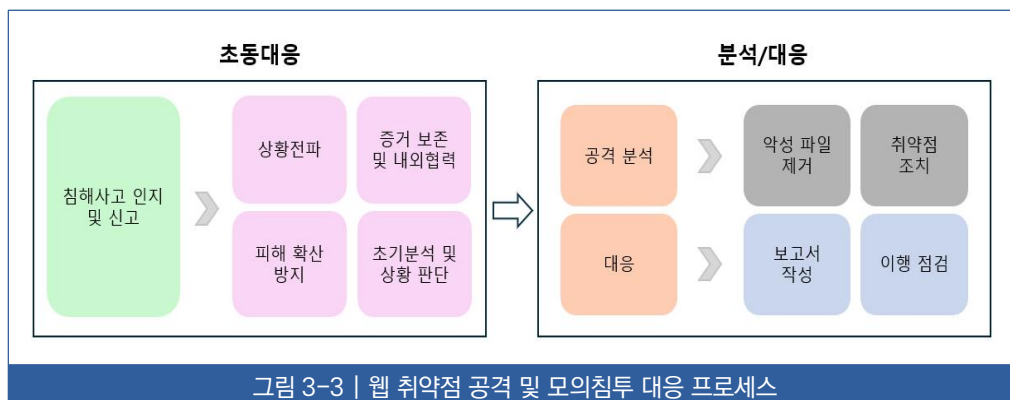
<신고방법>

1. KISA 인터넷 보호나라(boho.or.kr) > '침해사고 신고' 선택

웹 취약점 점검은 기업의 웹 시스템 및 관련 자원에 대해 해킹에 취약할 수 있는 근본적인 문제를 파악하고, 보안상 미비점에 대한 상세 설명과 해결 방안을 제시함으로써 서비스 운영 중 발생 가능한 보안 위협 요소를 사전에 예방하는 활동입니다. 주요 목적은 웹 애플리케이션의 보안 수준을 진단하고, 식별된 취약점에 대한 개선 대책을 수립하여 안전하고 신뢰성 있는 웹 서비스를 제공하는 데 있습니다.

모의침투는 실제 해커의 관점에서 다양한 공격 기법과 침투 경로를 이용하여 대상 시스템의 보안 취약점을 능동적으로 식별하고, 해당 취약점이 실제로 악용될 수 있는지 검증하는 과정입니다. 이를 통해 기업은 잠재적인 보안 위협을 사전에 파악하고 실질적인 대응 방안을 수립하여 정보 자산을 보호할 수 있습니다. 모의침투는 단순한 취약점 스캔을 넘어, 여러 취약점을 연계한 복합적인 공격 시나리오를 통해 시스템의 방어 능력을 종합적으로 평가합니다.

웹 취약점 공격 및 모의침투 대응 프로세스는 다음과 같습니다.



1. 초동대응

웹 공격 발생 시 신속하고 체계적인 초동대응은 피해를 최소화하고 효과적인 사고 분석 및 복구를 위한 첫걸음입니다. 초동대응은 침해사고를 인지하는



순간부터 시작되며, 관련 법규 준수와 함께 내부 절차에 따른 즉각적인 조치가 요구됩니다.

① 침해사고 인지 및 신고

- 정보통신서비스 제공자는 침해사고 발생을 인지한 경우, 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제48조의3에 따라 24시간 이내에 과학기술정보통신부 장관 또는 한국인터넷진흥원(KISA)에 신고해야 합니다. KISA 보호나라(boho.or.kr) 웹사이트를 통해 침해사고 신고가 가능하며, 신고 시 침해사고 유형, 기업 정보, 사고 현황, 대응 현황 등을 포함해야 합니다. 신속한 신고는 KISA로부터 기술 지원 및 대응 자문을 받는 데 도움이 될 수 있습니다.

(신고 방법은 '3.1. 참고 사항'참조)

② 상황 전파 및 대응팀 가동

- 침해사고 발생 사실을 내부 관련 부서 및 책임자에게 신속히 전파하고, 사전에 구성된 침해사고 대응팀을 즉시 가동합니다.

③ 증거보존

- 법적 대응 및 정확한 원인 분석을 위해 공격과 관련된 로그, 시스템 이미지, 네트워크 트래픽 등 디지털 증거가 훼손되지 않도록 안전하게 수집하고 보존합니다.

④ 초기 분석 및 상황 판단



- 공격 유형(예: 웹셸 업로드, SQL 인젝션을 통한 데이터 유출, DDoS 등), 공격 근원지, 피해 범위, 시스템 중요도 등을 신속하게 파악하여 대응 우선순위를 결정합니다.

⑤ 외부 기관 협력

- KISA 등 관련기관에 신고하고, 필요한 경우 기술 지원 및 협조를 요청합니다.

2. 분석/대응

침해사고 발생 후 또는 정기적인 보안 강화를 위해 웹 취약점에 대한 심층적인 분석과 이에 기반한 체계적인 대응 방안 수립이 필수적입니다. 본 절에서는 KISA의 주요정보통신기반시설 기술적 취약점 분석·평가 가이드라인을 중심으로 주요 웹 취약점 대응 방안을 설명하고, 나아가 국제적으로 널리 참조되는 OWASP Top 10 주요 항목에 대한 분석과 대응 전략을 제시합니다.

취약점 유형	핵심 대응 방안	관련 OWASP Top 10
SQL 인젝션 (SQL Injection)	Prepared Statement 사용, 입력값 유효성 검증 및 이스케이프 처리, 웹 방화벽(WAF) 활용	A03:2021-Injection
크로스사이트 스크립트 (XSS)	컨텍스트 기반 출력 인코딩, 입력값 유효성 검증, Content Security Policy(CSP) 적용, WAF 활용	A03:2021-Injection



파일 업로드 (File Upload)	확장자 화이트리스트 검증, 파일 시그니처 검증, 저장 경로 웹 루트 외부 지정 또는 실행 권한 제거, 파일명 난수화, 안티바이러스 스캔, WAF 활용	A01:2021-Broken Access Control, A05:2021-Security Misconfiguration, A08:2021-Software and Data Integrity Failures
경로 조작 및 자원 삽입 (Path Traversal)	입력값 필터링 (../ / 등), 경로 정규화, 사용자 권한 기반 접근 제어, 파일 시스템 접근 최소화	A01:2021-Broken Access Control
중요자원 접근통제 (Access Control for Critical Resources)	역할 기반 접근 통제(RBAC), 최소 권한 원칙 적용, 접근 제어 목록(ACL) 설정, URL 및 기능 단위 접근 제어	A01:2021-Broken Access Control
세션 관리 취약점 (Session Management Vulnerabilities)	예측 불가능한 세션 ID 사용, 로그인 시 세션 ID 재발급, 안전한 쿠키 속성 (HttpOnly, Secure, SameSite) 설정, 적절한 세션 타임아웃 설정	A07:2021-Identification and Authentication Failures
부적절한 에러 처리 (Improper Error Handling)	상세 오류 메시지 사용자 노출 금지, 표준화된 오류 페이지 사용, 중요 오류는 로깅	A05:2021-Security Misconfiguration
디렉터리 인덱싱 (Directory Indexing)	웹 서버 설정 변경을 통해 디렉터리 리스팅 기능 비활성화	A05:2021-Security Misconfiguration
관리자 페이지 노출 (Admin Page Exposure)	관리자 페이지 경로 복잡화, 접근 IP 제한, 별도 인증 강화 (MFA 등)	A01:2021-Broken Access Control, A05:2021-Security Misconfiguration

< KISA 주요통신기반시설 주요 기술적 취약점과 OWASP Top 10 관련성 >

1) KISA 주요정보통신기반시설 주요 기술적 취약점 분석 및 대응

한국인터넷진흥원(KISA)에서 발간하는 "주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드"[38] 는 국내 주요정보통신기반시설의 안전성 확보를 위한 핵심 지침서로, 웹 애플리케이션을 포함한 다양한 시스템 구성 요소별 취약점 점검 항목과 조치 방안을 구체적으로 제시하고 있



습니다. 이 가이드라인은 국내 법규 준수의 기준이 되기도 하며, OWASP Top 10 등 국제적인 보안 표준과도 많은 부분을 공유합니다. 따라서 KISA 가이드라인을 기준으로 취약점을 분석하고 대응하는 것은 국내 환경에서 기본적인 보안 수준을 확보하는 데 매우 중요합니다.

주요 취약점 점검 및 대응 방법은 다음과 같습니다.

2) 주요 취약점 점검 및 대응

공격방법	취약점 개요 및 설정 방법
SQL 인젝션	(점검 목적) 사용자의 입력값으로 웹 사이트 SQL 쿼리가 완성되는 약점을 이용 하며, 입력값을 변조하여 비정상적인 SQL 쿼리를 조합하거나 실행하는 공격. 개발자가 생각지 못한 SQL문을 실행되게 함으로서 DB를 비정상적으로 조작 가능 ※ 소스코드 및 취약점 점검 필요
	(보안위협) 해당 취약점이 존재하는 경우 비정상적인 SQL 쿼리로 DBMS 및 데이터를 열람하거나 조작 가능하므로 사용자의 입력값에 대한 필터링을 구현
	점검방법 예: 1) 애플리케이션 인수 값에 특수문자나 임의의 SQL 쿼리를 전달하여 DB 에러 페이지가 반환 되는지 확인 2) 애플리케이션 인수 값에 임의의 SQL 참, 거짓 쿼리를 전달하여 참, 거짓 쿼리에 따라 반환되는 페이지가 다른지 확인 3) 로그인 창에 참이 되는 SQL 쿼리를 전달하여 로그인 되는지 확인



bb//bbs/board.php?bo_table=c107&wr_id=50 1

기(V) 즐겨찾기(A) 도구(T) 도움말(H)

bb//bbs/board.php?bo_table=c107&wr_id=50 2

기(V) 즐겨찾기(A) 도구(T) 도움말(H)

Searching for x' 3

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near "x" GROUP BY username ORDER BY username ASC' at line 1

This is the Query you executed (injection string is underlined):

SELECT username FROM users WHERE username LIKE 'x' GROUP BY username ORDER BY username ASC

board.php?bo_table=c107&wr_id=50' and 'a'='a' 1

찾기(A) 도구(T) 도움말(H)

Proxy: (none)

Typed URLs Visited URLs Cache AutoFill

공지사항

board.php?bo_table=c107&wr_id=50' and 'a'='a' 2

찾기(A) 도구(T) 도움말(H)

Proxy: (none)

Typed URLs Visited URLs Cache AutoFill



MEMBER LOGIN

아이디

비밀번호

로그인

< SQL 인젝션 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드)

(보안설정 방법) SQL 쿼리에 사용되는 문자열의 유효성을 검증하는 로직 구현

아래와 같은 특수문자나 문구를 필터링하는 함수를 사용

(아래 문자/문구는 예시로 해당 데이터베이스에 따라 달라질 수 있음)

문자	설명	문구	설명
'	문자 데이터 구분기호	UNION	여러 쿼리들을 합침
;	쿼리 구분 기호	AND	where 절 연산자
--, #	해당라인 주석 구분 기호	SELECT	데이터 조회
/* */	*와 */ 사이 구문 주석	FROM	sql 기본 문법

* Dynamic SQL 구문 사용을 지양하며 파라미터에 문자열 검사 필수 적용

* 파라미터 쿼리 사용

* 시스템에서 제공하는 에러 메시지 및 DBMS에서 제공하는 에러 코드가 노출되지 않도록 예외처리

* 웹 방화벽에 인젝션 공격 관련 설정

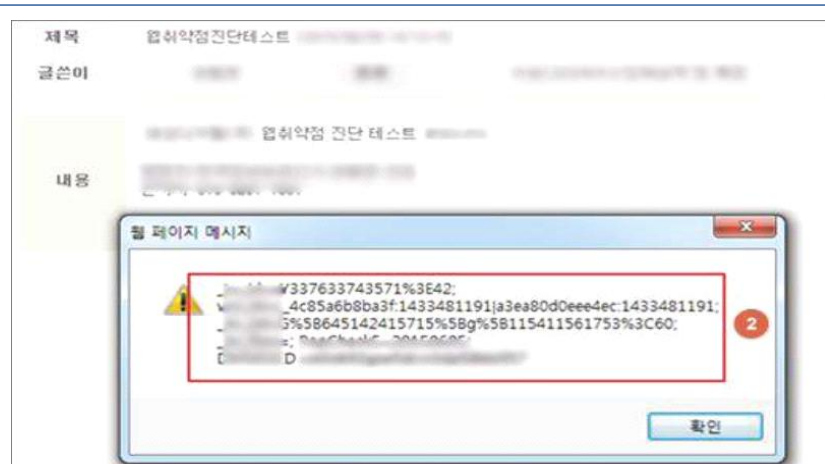
■ 사용하는 언어별(ASP.net, JSP, PHP)로 문자열 유효성 검증 로직 구현

→ 상세 언어별 문자열 필터링 적용 방법은 「주요정보통신기반시설 기술적 취약점 분석평가 방법 상세 가이드」 문서 655~658 페이지 참고

< 입력값 검증 부재 : SQL 인젝션 취약점 >

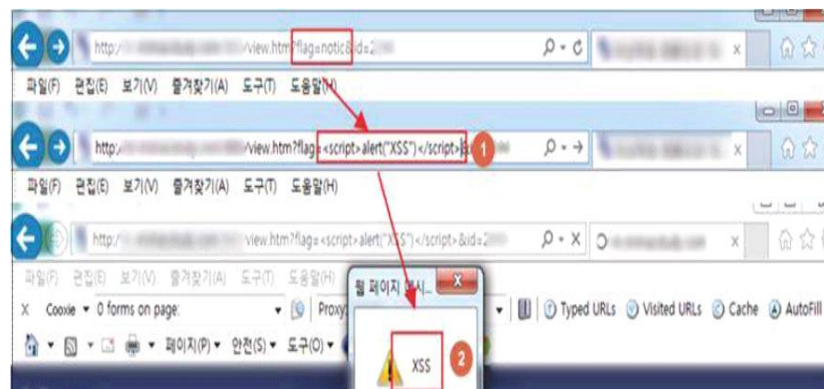


공격방법	취약점 개요 및 대응
Cross Site Scripting(XSS) 취약점	(점검 목적) 웹 사이트 내 크로스 사이트 스크립팅 취약점을 제거하여 악성 스크립트의 실행을 차단
	(보안위협) 공격자는 사용자 입력값을 받는 게시판, URL 등에 악의적인 스크립트(Javascript, VBScript, ActiveX, Flash 등)를 삽입하여 게시글을 읽는 사용자의 쿠키(세션)를 탈취하여 도용하거나 악성코드 유포 사이트로 Redirect 할 수 있음 ※ 소스코드 및 취약점 점검 필요
	점검방법 예: 1) 사용자 인수 값을 입력받는 애플리케이션(회원정보 변경, 게시판, 댓글, 자료실 등)에 스크립트 입력 후 실행되는지 확인  <게시글 내용에 스크립트 삽입(stored)>



<스크립트 코드 동작 >

- 2) 사용자 인수 값을 입력받는 애플리케이션(검색, URL)에 스크립트 입력 후 실행되는지 확인



< 크로스사이트 스크립팅 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드) >

(보안설정 방법)

- * 웹 사이트에 사용자 입력값이 저장되는 페이지(게시판, 1:1 문의 등)는 공격자가 웹 브라우저를 통해 실행되는 스크립트 언어 (HTML, JavaScript, VBScript 등)를 사용하여 공격하므로 해당되는 태그 사용을 사전에 제한하고, 사용자 입력값에 대한 필터링 작업이 필요



	* 게시물의 본문뿐만 아니라 제목, 댓글, 검색어 입력 창, 그 외 사용자 측에서 넘어오는 값을 신뢰하는 모든 form과 파라미터 값에 대해서 필터링을 수행 ※ 필터링 조치 대상 입력 값 · 스크립트 정의어 : <SCRIPT>, <OBJECT>, <APPLET>, <EMBED>, <FORM>, <IFRAME> 등 · 특수문자 : <, >, ", ', &, %, %00(null) 등 ■ 웹 애플리케이션 별(ASP, PHP, JSP) 상세 설정은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드」 문서 675~676 페이지 참고 < 입력값 검증 부재 : Cross Site Scripting 취약점 >
--	--

공격방법	취약점 개요 및 설정 방법
파일 업로드 (File Upload)	(점검 목적) 웹 사이트의 게시판, 자료실 등에 조작된 Server Side Script 파일 업로드 및 실행 가능 여부 점검
	(보안위협) 해당 취약점이 존재할 경우 공격자는 조작된 Server Side Script 파일을 서버에 업로드 및 실행하여 시스템 관리자 권한 획득 또는 인접 서버에 대한 침입을 시도할 수 있음 ※ Server Side Script : 웹에서 사용되는 스크립트 언어 중 서버측에서 실행되는 스크립트 ※ 소스코드 및 취약점 점검 필요
	점검방법 예: 1) 사용자 게시판의 파일 첨부 기능 존재 유무 확인



공지사항

공지사항

:: 글쓰기 ::

옵션 ☐ 공지

제목

내용

링크 #1

링크 #2

파일첨부

찾아보기...

글쓰기 목록

- 2) 웹 사이트에 파일 업로드 기능이 존재하는 경우, 확장자가 .jsp, .php, .asp, .cgi 등 Server Side Script 파일들이 업로드 가능한지 확인

※ 클라이언트에서 JavaScript, VBScript 등의 스크립트로 파일 첨부을 차단하는 경우 차단 기능 수정하여 파일 첨부 가능

공지사항

공지사항

작성일 : 11-02-14 18:37

복사

이동

목록

수정

삭제

답변

글쓰기

공지사항

스크랩 트랙백

글쓴이 : ...

조회 : 2,651

test.php (7byte)

test.php (7byte)

이전글

복사

이동

목록

수정

삭제

답변

글쓰기

- 3) 홈페이지에 있는 디렉터리 정보를 이용하여 첨부한 Server Side Script 프로그램의 위치를 조사한 후 브라우저 주소 창에서 해당 프로그램의 실행이 가능한지 확인



< 파일 업로드 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드)

(보안설정 방법) 업로드 되는 파일에 대한 확장자 검증 및 실행 권한 제거

※ 사용자가 파일을 업로드 할 수 있는 모든 모듈에 적용 필요

* 화이트리스트 방식으로 허용된 확장자만 업로드 가능토록 서버측 통제 적용

* 업로드 되는 파일을 디렉토리에 저장할 때 파일명과 확장자를 외부 사용자가 추측할 수 없는 문자열로 변경하여 저장(파일 이름은 DB에 저장)

* 업로드 파일을 위한 전용 디렉토리를 별도로 생성하여 웹 서버 데몬 설정 파일(httpd.conf 등)에서 실행 설정을 제거함으로써, Server Side Script가 업로드 되더라도 웹 엔진이 실행하지 않는 환경을 설정

* 파일 업로드 필드를 대상으로 특수문자 필터링하도록 웹 방화벽 룰셋 적용

※ 유형별 상세 설정

■ 웹 애플리케이션 별(ASP, ASP.net JSP, PHP) 설정은 「주요정보통신기반시설 기



술적 취약점 분석·평가 방법 상세 가이드」 문서 701~704 페이지 참고

```
.....
// 파일 이름에 특수문자가 있을 경우 업로드를 금지시킴
if (ereg( "[^a-z0-9 \. _ \-] ", $_FILES[ 'userfile' ][ 'name' ] ))
print "파일 이름의 특수문자 체크" ;
exit;
// 파일 확장자 중 업로드를 허용할 확장자를 정의함
$full_filename = explode( ".", $_FILES[ 'userfile' ][ 'name' ] );
$extension = $full_filename[ sizeof($full_filename)-1 ];
$extension= strtolower($extension);
if ( !( ereg( "$extension", "hwp" ) || ereg( "$extension", "pdf" )
|| ereg( "$extension", "jpg" ) ) )
print "업로드 금지 파일입니다" ;
exit;
.....
```

<PHP에서 수용 가능한 파일 확장자만 업로드 허용방식(문자열 비교) 예>

■ 웹 서버 별(Apache, IIS) 설정은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드」 문서 704~705 페이지 참고

* 업로드 파일 실행 권한 제거시 웹셸 업로드에 성공하더라도, 업로드 파일의 실행 권한이 없으면 웹셸은 작동하지 않는다.



	1. 파일 업로드 디렉토리로 이동 2. root 권한으로 실행 권한 삭제 명령 예시) <code>#chmod 644 /var/www/html/</code> 3. 실행 권한 제거 확인 예시) <code>#ls -alrw-r--r-- 3 root root 4096 10월 10 13:45 html</code> <리눅스 기반 웹 서버 실행 권한 제거 방법> 1. [관리 도구] - “IIS(인터넷 정보 서비스) 관리자” 를 실행 2. 좌측의 사이트 목록에서 실행 권한을 제거할 업로드 폴더 선택 3. [처리기 매핑]을 클릭한 후 우측이 [기능 사용 권한 편집] 클릭 4. “스크립트” 를 선택 해제하고 [확인] 버튼 클릭 <윈도우 기반 IIS 서버 실행 권한 제거 방법> ■ 웹 방화벽 : 웹셀에 주로 사용되는 문자열, 오브젝트, 메소드 등을 시그니처로 지정하여 파일 업로드 시 탐지 및 차단 < 입력값 검증 부재 : 파일 업로드 >
--	---

공격방법	취약점 개요 및 설정 방법
파일 다운로드	(점검 목적) 파일 다운로드 시 허용된 경로 외 다른 경로의 파일 접근을 방지하여 공격자가 임의의 위치에 있는 파일을 열람하거나 다운받는 것을 불가능하게 하기 위함 (보안위협) 해당 취약점이 존재할 경우 공격자는 파일 다운로드 시 애플리케이션의 파라미터 값을 조작하여 웹 사이트의 중요한 파일(DB 커넥션 파일, 애플리케이션 파일 등) 또는 웹 서버 루트에 있는 중요한 설정 파일(passwd, shadow 등)을 다운 받을 수 있다. 또한, 애플리케이션에서 입력되는 경로를 검증하지 않는 경우 임의의 문자 (../.. 등)나 주요 파일명의 입력을 통해 웹 서버의 홈 디렉토리를 벗어나서 임의의 위치에 있는 파일을 열람하거나 다운받는 것이 가능하다. ※ 소스코드 및 취약점 점검 필요



점검방법 예:

- 1) 웹 사이트에 cgi, jsp, php 등의 애플리케이션을 이용하여 파일을 다운받는 페이지가 있는지 조사

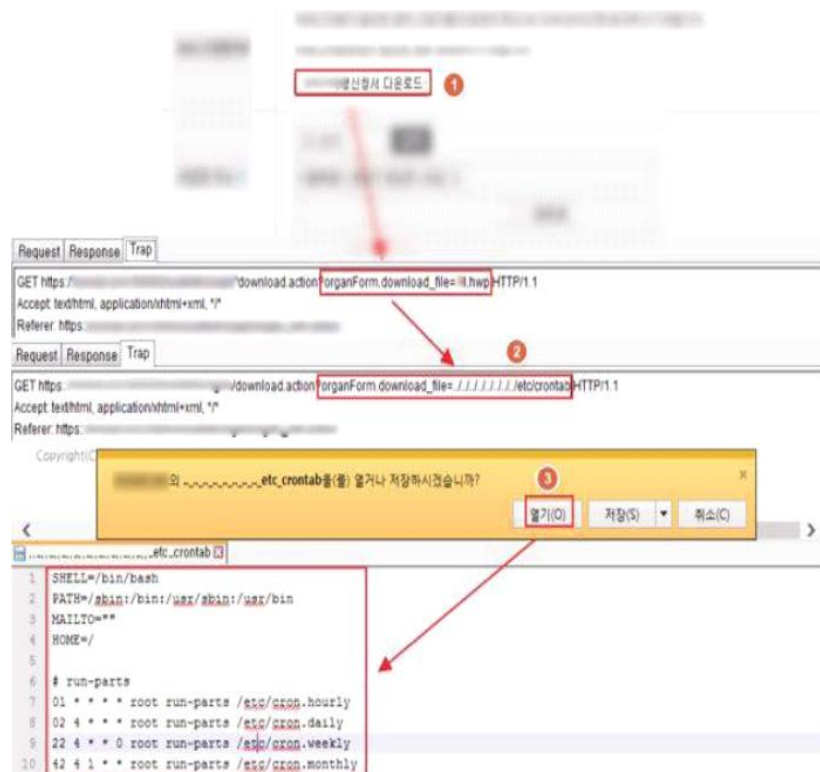
공개정보공유

The screenshot shows a web page titled '공개정보공유' (Public Information Sharing). It displays a file named '알성화 계획(15년11월)' (Alseonghwa Plan (Nov 2015)) with a size of 3.1M. Below the file name, there is a download link. A red box highlights the download link. Below the screenshot, a network traffic log is shown with a red box highlighting the URL of the download request.

me	Sent	Received	Method	Result	Type	URL
712	780	3296286	GET	200		https://.../bbs/download.php?bo_table=c403&wr_id=76&no=0

- 2) 웹 사이트에서 파일 다운로드 시 요청(Request) 정보에 파일 경로를 웹 서버(웹사이트 포함) 중요 파일(winnt\win.ini, /etc/passwd 등의 상대 경로(..))로 치환한 후 전송했을 때 해당 경로 파일들을 다운로드 가능한지 확인

../..../..../..../etc/passwd
 ../..../..../..../winnt/win.ini
 ../..../..../..../boot.ini



3) 2)에서 변조하여 전송한 애플리케이션 인수 값을 아래의 인코딩 (또는 치환, 종단문자 추가)을 적용하고 전송하여 인수 값으로 전송한 해당 경로 파일의 내용이 웹 브라우저에 표시되거나 파일로 다운로드 되는지 확인

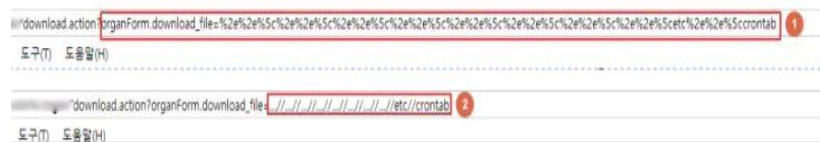
URL 인코딩 - .(%2e), /(%2f), ₩(%5c)

16bit 유니코드 인코딩 - .(%u002e), /(%u2215), w(%u2216)

더블URL 인코딩 - .(%252e), /(%252f), w(%255c)

경로 치환 - ...//, ...~~WW~~, ...~~W~~/, .../~~W~~

종단 문자 추가 - [파일명]%00.jpg, [파일명]%0a.jpg





	< 파일 다운로드 > (출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드) (보안설정 방법) 다운로드 시 허용된 경로 이외의 디렉토리와 파일에 접근할 수 없도록 구현 * 파일 다운로드의 취약성은 주로 파일의 이름을 조작하는 데서 비롯되므로 다운로드 파일 이름을 데이터베이스에 저장하고 다운로드 수행 시 요청 파일 이름과 비교하여 적절한지 확인하여 사용자가 조작할 수 있는 변수를 제거 * 다운로드 애플리케이션 소스 파일을 수정하여 파일을 다운받을 수 있는 디렉 토리를 특정 디렉토리로 한정하고 이 외의 다른 디렉토리에서는 파일을 다운로드 받을 수 없도록 설정 * 다운로드 시 사용되는 파라미터 값 대상으로 아래의 특수 문자를 필터링하도록 웹 방화벽 룰셋 적용 ■ 웹 애플리케이션 별(ASP, ASP.net JSP, PHP) 설정은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드」 문서 709~710 페이지 참고 < 입력값 검증 부재 : 파일 다운로드 >
--	--

공격방법	취약점 개요 및 설정 방법
불충분한 세션 만료	(점검 목적) 세션 타임아웃 기능을 구현하여 공격자가 만료되지 않은 세션 활용을 방지하기 위함
	(보안위협) 세션 만료 기간을 정하지 않거나, 만료기한을 너무 길게 설정한 경우 악의적인 사용자가 만료되지 않은 세션을 활용하여 불법적인 접근이 가능할 수 있다.
	점검방법 예: 1) 인증 후 정상적으로 세션이 발행된 페이지의 리퀘스트를 취득하여 일정 시간(사이트에 따라 다름)이 지난 후에 재전송 시 정상 처리가 되는지 확인

ONLINE BANKING LOGIN	PERSONAL
PERSONAL • Deposit Product • Checking • Loan Products • Cards • Investments & Insurance • Other Services SMALL BUSINESS • Deposit Products • Lending Services • Cards • Insurance • Retirement • Other Services INSIDE ALTORO MUTUAL • About Us • Contact Us • Locations • Investor Relations • Press Room • Careers	Online Banking Login Username: test0258 Password: ***** Login

<로그인 후 세션 발급>

MY ACCOUNT	PERSONAL
I WANT TO ... • View Account Summary • View Recent Transactions • Transfer Funds • Search News Articles • Customize Site Language ADMINISTRATION • View Application Values • Edit Users	Hello Admin User Welcome to Altoro Mutual Online. View Account Details: GO

<일정 시간 경과 후 세션 유지 여부 확인>

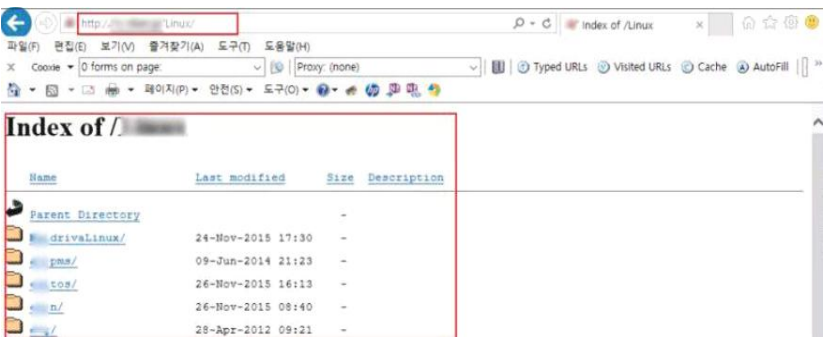
< 불충분한 세션 만료 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드)

(보안설정 방법) 세션 종료 시간 설정 및 자동 로그아웃 기능 구현
- 세션 타임아웃 구현 시 타임아웃 시간은 10분으로 설정할 것을 권고

■ 웹 애플리케이션 별(ASP, JSP) 설정은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드」 문서 691~692 페이지 참고



공격방법	취약점 개요 및 설정 방법
디렉터리 인덱싱 취약점	(점검 목적) 특정 디렉토리에 초기 페이지(index.html, home.html, default.asp 등) 파일이 존재하지 않을 때 자동으로 디렉토리 리스트를 출력하는 취약점
	(보안위협) 해당 취약점이 존재할 경우 브라우저를 통해 특정 디렉토리 내 파일 리스트를 노출하여 응용시스템의 구조를 외부에 허용할 수 있고, 민감한 정보가 포함된 설정 파일 등이 노출될 경우 심각한 위험을 초래할 수 있다.
	점검방법 예: 1) URL 경로 중 확인하고자 하는 디렉토리까지만 주소창에 입력하여 인덱싱 여부 확인 
	2) 디렉토리 끝에 %3f.jsp 문자열을 붙여 디렉토리 인덱싱이 되는지 확인  < 디렉터리 인덱싱 > (출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드) (보안설정 방법) 웹 서버 환경설정에서 디렉토리 인덱싱 기능 제거 ※ 웹 서버 별 상세 설정 ■ Apache



	httpd.conf 파일 내 DocumentRoot 항목의 Options에서 Indexes 제거 Indexes가 해당 디렉토리의 파일 목록을 보여주는 지시자임 설정 전 <pre><Directory "/var/www/html"> Options Indexes </Directory></pre> 설정 후 <pre><Directory "/var/www/html"> Options </Directory></pre> ■ IIS 7.5/8.0/8.5/10.0 IIS(인터넷 정보 서비스) 관리자 > [해당 웹 사이트] > [IIS] > [디렉토리 검색] 선택 우측의 [사용 안 함] 버튼을 눌러 비활성화 < 부적절한 환경설정 : 디렉터리 인덱싱 취약점 >
--	--

공격방법	취약점 개요 및 설정 방법
관리자 페이지 노출	(점검목적) 서버와 클라이언트 간 통신 시 데이터의 암호화 전송 미흡으로 정보 유출의 위험을 방지하고자 한다.
	(보안위협) 웹상의 데이터 통신은 텍스트 기반으로 이루어지기 때문에 서버와 클라이언트 간에 암호화 프로세스를 구현하지 않으면 간단한 도청(Sniffing)을 통해 정보를 탈취 및 도용할 수 있다. ※ Sniffing(스니핑) : 네트워크상의 데이터를 도청하는 행위 ※ 소스코드 및 취약점 점검 필요
	점검방법 예: 1) 중요정보(인증정보, 개인정보 등)를 송수신하는 페이지 존재 여부 확인

The screenshot shows a web page for member login. At the top, there is a header with a logo and the text "MEMBER LOGIN". Below this, there is a login form with two input fields: "아이디" (ID) and "비밀번호" (Password). The ID field contains the text "lovelovelove". The password field is masked with dots and has a red box around it with a red circle containing the number "1". To the right of the password field is a "로그인" (Login) button. Below the login form, there is a section for "아이디" (ID) with a link to "비밀번호 찾기" (Find Password) and a note "(2013년 12월 25일 10시 12분에 가입)" (Joined on December 25, 2013 at 10:12). Below this, there is a section for "패스워드" (Password) with a red box around it and a red circle containing the number "2". Below the password section, there is a section for "별명" (Nickname) with a link to "별명 변경" (Change Nickname) and a note "닉네임은 한 번 게시판에 사용될 예정입니다." (The nickname will be used on the bulletin board once). Below the nickname section, there is a section for "러브러브" (Love Love) with a link to "러브러브" (Love Love) and a note "2~16자 한글, 영문, 숫자" (2~16 characters, Korean, English, numbers). Below the love love section, there is a section for "비밀번호" (Password) with a red box around it and a red circle containing the number "3". Below the password section, there are two buttons: "가입하기" (Join) and "이전" (Previous).

2) 중요정보 송수신 페이지가 암호화 통신(https, 데이터 암호화 등)을 하는 지 확인

[illegible]

< 데이터 평문 전송 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드)

3) 취약한 버전의 암호 프로토콜 사용시 암호화된 통신 내용이 유출
될 수 있어 취약한 버전의 SSL(SSL 2.0, 3.0) 사용 여부를 점검

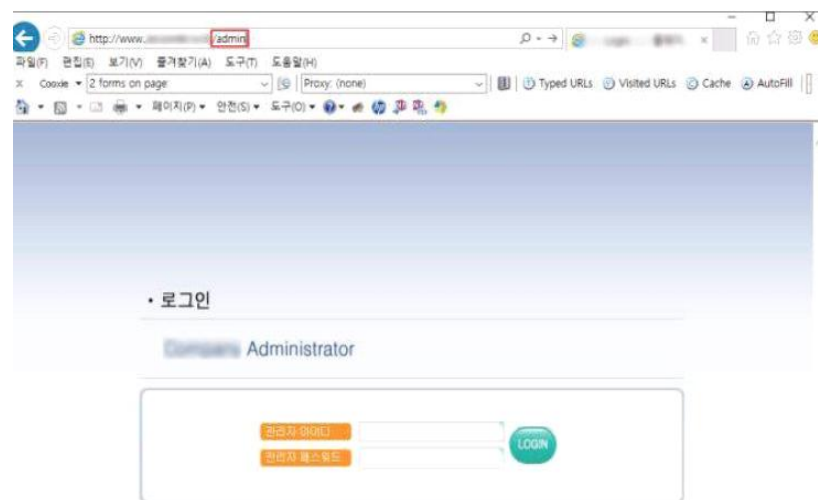
보안설정 방법)

* 웹상에서의 전송 정보를 제한하여 불필요한 비밀번호, 주민등록

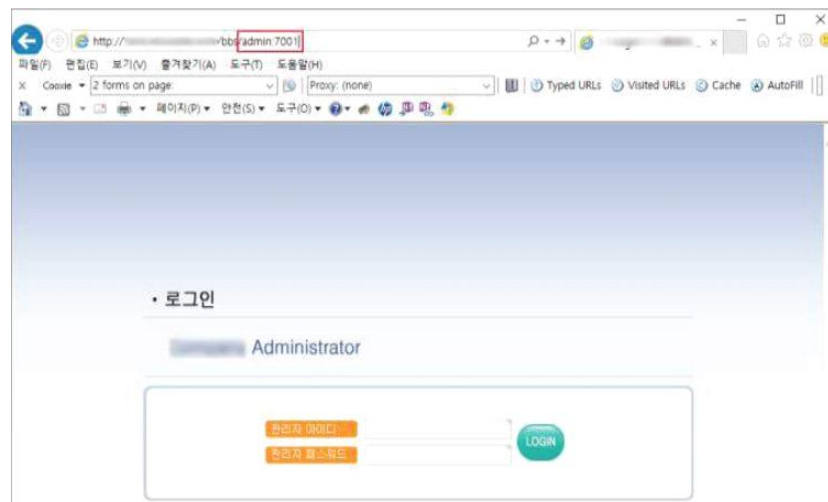


	번호, 계좌정보와 같은 중요정보의 전송을 최소화하여야 하며, 중요정보에 대해서는 반드시 SSL 등의 암호화 통신을 사용하여 도청으로부터의 위험을 제거한다. * 쿠키와 같이 클라이언트 측에서 노출되는 곳에 비밀번호, 인증인식 값, 개인정보 등의 정보를 기록하지 않는다. * 암호화 전송시 프로토콜 설계의 결함이 있는 SSLv2, SSLv3, TLSv1.0, TLSv1.1은 비활성화 필수, TLSv1.2 이상 사용을 권장한다. ※ 웹 서버 별 상세 설정 ■ 웹 서버 별(Apache, IIS) 상세 설정은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세 가이드」 문서 720 페이지 참고 < 취약한 정보저장 방식 : 통신 상 중요정보 노출 취약점 >
--	---

공격방법	취약점 개요 및 설정 방법
관리자 페이지 노출	(점검 목적) 관리자 페이지 URL이 유추하기 쉬운 이름(admin, manager 등) 및 웹사이트 설계 오류를 수정하여 비인가자의 관리자 메뉴 접근을 방지하고자 한다.
	보안위협) 웹 관리자의 권한이 노출될 경우 웹 사이트의 변조 뿐만 아니라 취약성 정도에 따라서 웹 서버의 권한까지도 노출될 수 있다. ※ 소스코드 및 취약점 점검 필요
	점검방법 예: 1) 추측하기 쉬운(/admin, /manager, /master, /system, /administrator 등)의 명칭을 사용하는 디렉터리 및 파일 관리자 페이지 존재 여부 확인



- 2) 추측하기 쉬운 포트(7001, 8080, 8443, 8888 등) 포트의 접속으로 관리자 페이지가 노출되는지 확인



- 3) 관리자 페이지의 로그인 창에 기본 관리자 계정(admin, administrator, manager 등) 및 패스워드를 입력하여 로그인 가능한지 확인



- 4) 사용자 인증 후 접근한 관리자 페이지 메인 페이지나 하위 메뉴 페이지 등 중간 페이지(/admin/main.asp, /admin/menu.html 등) URL으로 인증 과정 없이 직접 접근 가능한지 확인



< 관리자 페이지 노출 >

(출처: KISA 주요정보통신기반시설 기술적 취약점 분석평가 가이드)

(보안설정 방법)

- * 일반 사용자의 접근이 불필요한 관리자 로그인 페이지 주소를 유추하기 어려운 이름으로 변경하고 관리자 페이지 접근 포트도 변경
- * 관리자 페이지 주소를 직접 입력하여 접근하지 못하도록 관리자 페이지



	이지 각각에 대하여 관리자 인증을 위한 세션 관리 * 중요한 정보를 가진 웹 서버의 특정 페이지들은 관리자 또는, 특정 사용자만 접근할 필요가 있으므로 이러한 주요 페이지들은 웹 서버에서 적절한 설정을 통하여 특정 사용자만 접근이 가능하도록 사용자 접근 제한이 필요함 * 웹 방화벽을 이용하여 특정 IP만 접근 가능하도록 제한 < 취약한 접근통제 : 관리자 페이지 노출 >
--	--

3) OWASP Top 10 취약점 심층분석 및 대응

① A01:2021 - Broken Access Control (접근 권한 손상)

항목	내용
공격 유형	접근 권한 우회 (URL 조작, 파라미터 변조 등)
공격 사례	MGM 리조트, MFA 피로공격을 통한 접근 후 랜섬웨어 유포
대응 방안	- 서버측에서 접근 권한 철저 검증 - 비인가 요청 시 403 Forbidden 반환 - 민감 기능에 대한 리소스 단위 권한 검증 - 테스트 코드 및 툴을 활용한 권한 우회 탐지 - ACL(Access Control List) 및 RBAC 모델 도입

< A01:2021 - Broken Access Control (접근 권한 손상) 대응 >

② A02:2021 - Cryptographic Failures (암호화 오류)

항목	내용
공격 유형	암호화 미적용, 약한 알고리즘, 키 관리 실패
공격 사례	트위터 API 통해 개인정보 수집 후 다크웹 유출
대응 방안	- AES, RSA 등 검증된 알고리즘 사용 - 키 관리 시스템(KMS) 활용 - 전송 구간 TLS 1.2 이상 적용 - 저장 데이터에 대한 암호화 적용



	- 개인정보 마스킹 및 해싱 저장 적용 (비밀번호는 Bcrypt 등)
< A02:2021 - Cryptographic Failures (암호화 오류) 대응 >	

③ A03:2021 – Injection (인젝션)

항목	내용
공격 유형	SQL, OS 명령어, LDAP, XSS 등 인젝션
공격 사례	MOVEit Transfer SQL 인젝션으로 6천만명 피해
대응 방안	- Prepared Statement 또는 ORM 사용- 입력값 유효성 검증 및 정규화- 에러 메시지 최소화 및 상세 정보 노출 금지- 입력 필터링 및 콘텐츠 보안 정책(CSP) 적용- 보안 테스트 자동화 도구 도입 (SAST/DAST)
< A03:2021 - Injection (인젝션) 대응 >	

④ A04:2021 - Insecure Design (안전하지 않은 설계)

항목	내용
공격 유형	보안 미고려 설계, 위협 모델링 미흡
공격 사례	WordPress 사이트 무단 편집 가능 상태로 방치
대응 방안	- 설계 초기 단계부터 위협 모델링 수행 - 보안 아키텍처 리뷰 도입 - 최소 권한 원칙과 보안 설계 패턴 적용 - DevSecOps 문화 내재화 - 설계 문서 내 보안 요구사항 명시
< A04:2021 - Insecure Design (안전하지 않은 설계) 대응 >	

⑤ A05:2021 - Security Misconfiguration (보안 설정 오류)

항목	내용
공격 유형	기본 계정 사용, 디버깅 모드 유지, 패치 누락



공격 사례	Falcon Sensor 업데이트 오류로 BSOD 발생
대응 방안	- 불필요한 포트/기능 비활성화 - 기본 계정 삭제 및 비밀번호 변경 - 정기적인 보안 설정 점검 자동화 (CIS Benchmarks 등) - 설정 백업 및 롤백 플랜 준비 - 보안 패치 관리 체계 수립 및 자동화

< A05:2021 - Security Misconfiguration (보안 설정 오류) 대응 >

⑥ A06:2021 - Vulnerable and Outdated Components (취약하고 오래된 구성 요소)

항목	내용
공격 유형	보안 패치 누락된 오픈소스 라이브러리 사용
공격 사례	Log4Shell 취약점 2024년에도 여전히 악용
대응 방안	- 구성요소 목록(소프트웨어 BOM) 관리 - 자동 취약점 스캐닝 도입 (SCA 도구) - 패치 릴리스 모니터링 체계 운영 - 신뢰 가능한 저장소에서만 라이브러리 다운로드 - 정기적 보안 업데이트 수행 및 테스트

< A06:2021 - Vulnerable and Outdated Components (취약하고 오래된 구성 요소) 대응 >

⑦ A07:2021 - Identification and Authentication Failures (식별 및 인증 오류)

항목	내용
공격 유형	무차별 대입, MFA 미적용, 세션 탈취
공격 사례	KT 알파 기프트쇼 540만 회 로그인 시도, 9.8만 계정 탈취
대응 방안	- MFA 전면 적용 (OTP, 생체 등) - 비밀번호 정책 강화 (복잡도 + 주기 변경) - 로그인 시도 횟수 제한 및 계정 잠금 - 세션 타임아웃 설정- 인증 로그 이상탐지 (로그인 위치, IP 등)

< A07:2021 - Identification and Authentication Failures (식별 및 인증 오류) 대응 >

⑧ A08:2021 - Software and Data Integrity Failures (소프트웨어 및 데이터 무결성 오류)



항목	내용
공격 유형	무결성 미확인 업데이트, 역직렬화
공격 사례	WannaCry: SMB 취약점 통해 워밍 방식 전파
대응 방안	- 소프트웨어 서명 검증 및 코드 무결성 검사 - CI/CD 파이프라인에 보안 점검 통합 - 안전한 역직렬화 구현 (Whitelist Class 적용) - 배포 전 바이너리 정합성 해시 확인 - 변경 탐지 시스템 (FIM: File Integrity Monitoring) 도입

< A08:2021 - Software and Data Integrity Failures (소프트웨어 및 데이터 무결성 오류) 대응 >

⑨ A09:2021 - Security Logging and Monitoring Failures (보안 로깅 및 모니터링 오류)

항목	내용
공격 유형	로그 미생성, 모니터링 부재, 알림 누락
공격 사례	북한 라자루스 해킹 2년간 탐지 실패, 법원망 침입
대응 방안	- 보안 로그 필수 항목(접속, 권한변경 등) 수집 - 로그 중앙 수집(SIEM) 및 실시간 알림 설정 - 정기 로그 검토 및 위협 헌팅 수행 - 로그 조작 방지(불변 저장, HMAC 등) - 의심 활동 탐지 룰 강화

< A09:2021 - Security Logging and Monitoring Failures (보안 로깅 및 모니터링 오류) 대응 >

⑩ A10:2021 - Server-Side Request Forgery (SSRF) (서버 측 요청 위조)

항목	내용
공격 유형	서버 측에서 내부 자원 또는 외부 시스템 요청 조작
공격 사례	Microsoft Exchange SSRF 통해 인증 우회 및 원격 코드 실행
대응 방안	- 서버 요청 시 외부/내부 목적지 화이트리스트 적용 - 사용자 입력값 통한 URL 요청 차단 또는 검증 - 서버측에서 메타데이터 IP (169.254.x.x 등) 접근 차단



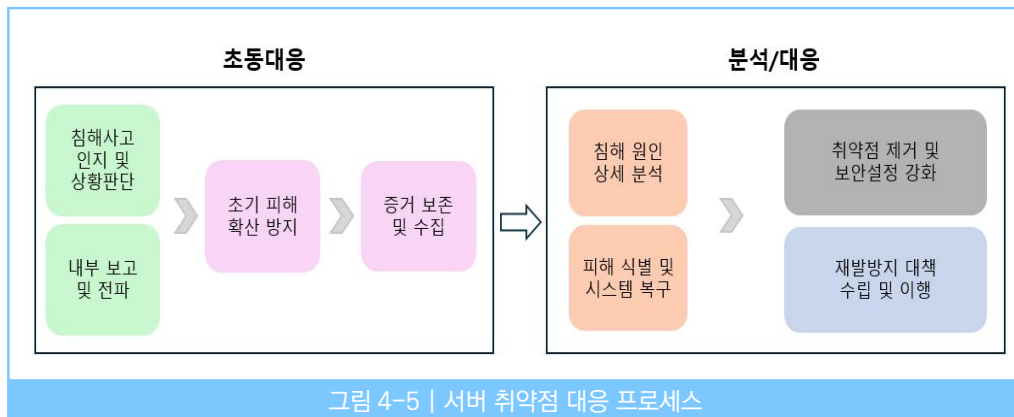
	약점(예: FreeFloat FTP Server의 SIZE 명령 처리 관련 서비스 거부 취약점, CVE-2024-0548) 등이 있습니다. 또한, 공격자가 탈취한 FTP 서버 계정을 이용하여 피싱 메일을 발송하거나 악성코드 유포를 위한 C2(Command & Control) 서버로 악용하는 사례도 있습니다.
SSH (Secure Shell) 서버 (Port 22)	- SSH 계정에 대한 무차별 대입 공격 및 사전 공격, Terrapin 공격(CVE-2023-48795, SSH 핸드셰이크 과정에서 시퀀스 번호를 조작하여 암호화 협상 과정을 약화시키는 공격), 패치되지 않은 OpenSSH 소프트웨어 자체의 취약점 등이 있습니다.
RDP (Remote Desktop Protocol) 서비스 (Port 3389)	- RDP 계정에 대한 무차별 대입 공격, BlueKeep(CVE-2019-0708)과 같은 RDP 프로토콜 자체의 원격 코드 실행 취약점, RDP 터널링을 통한 방화벽 우회 및 내부망 침투 등이 주요 위협입니다.
DNS (Domain Name System) 서버 (Port 53)	- DNS 서버를 이용한 증폭(Amplification) 및 반사(Reflection) DDoS 공격, DNS 캐시 포이즈닝(Cache Poisoning)을 통한 피싱 사이트 유도, DNS Zone Transfer 설정 오류로 인한 내부 네트워크 정보 노출 등이 있습니다.
이메일 서버 (SMTP: Port 25, POP3: Port 110, IMAP: Port 143 등)	- 오픈 릴레이(Open Relay) 설정을 통한 스팸 메일 및 피싱 메일 중계, 이메일 서버 소프트웨어 자체의 미패치된 취약점, 사용자 계정 정보 탈취를 통한 악성 메일 발송 등이 있습니다.

< 기타 주요 서비스 및 포트 취약점 공격 >

| 제 5 절 | 대응 방안

서버 취약점으로 인한 침해사고 발생 시, 체계적이고 효과적인 대응은 피해를 최소화하고 신속하게 서비스를 정상화하는 데 결정적인 역할을 합니다. 본 대응

방안은 미국의 국립표준기술연구소(NIST)의 SP 800-61^[77] 및 SANS Institute의 Incident Handler's Handbook^[78]과 같은 국제적인 표준 프레임워크를 기반으로 하며, 국내 환경에 맞춰 한국인터넷진흥원(KISA)의 관련 지침 및 법규를 통합하여 구성되었습니다.



1. 초동대응

① 침해사고 인지 및 상황 판단/ 전파

침해 징후 탐지: 보안 솔루션(IDS/IPS, 방화벽, WAF, 백신 등)의 경고, 시스템 및 네트워크 장비의 비정상적인 로그 패턴, 애플리케이션 오류 메시지 증가, 성능 저하, 내부 사용자 또는 외부 고객의 제보 등 다양한 경로를 통해 침해 징후를 인지합니다.

초기 분석 및 상황 판단: 인지된 징후를 바탕으로 실제 침해사고 발생 여부, 현재까지 확인된 피해 범위(영향받는 시스템, 네트워크, 애플리케이션 등), 공격의 출처 및 원인(추정), 공격 진행 상황 등을 신속하게 초기 분석하여 상황의 심각도를 판단합니다.

내부 보고 및 전파: 사전에 정의된 침해사고 대응 절차 및 보고 체계에 따라 관련 부서(IT 운영팀, 보안팀, 법무팀, 홍보팀 등) 및 책임자에게 신속하게 상



황을 보고하고 전파합니다. 사고의 심각도 및 예상 피해 규모에 따라 최고 경영진까지 보고가 이루어져야 합니다.

② 초기 피해 확산 방지

영향 시스템 격리: 감염되었거나 피해를 입은 것으로 의심되는 서버 또는 시스템을 네트워크로부터 즉시 분리합니다. 이는 물리적인 네트워크 케이블 제거, 방화벽에서의 해당 IP 차단, 가상 환경에서의 네트워크 인터페이스 비활성화 등의 방법으로 수행될 수 있습니다. 특정 서비스가 공격의 매개체로 사용된 경우 해당 서비스만을 일시적으로 중단할 수도 있습니다. 또한, 공격에 사용된 것으로 의심되는 계정은 즉시 비활성화하거나 비밀번호를 변경하여 추가적인 접근을 차단합니다.

공격 경로 차단: 방화벽, 침입 방지 시스템(IPS) 등의 보안 장비에서 공격자의 IP 주소, 악성코드가 유포되거나 통신하는 URL/도메인 등을 신속하게 차단합니다.

추가 피해 방지: 침해된 시스템과 동일한 취약점을 가질 가능성이 있는 다른 시스템들에 대해 긴급 보안 점검을 실시하고, 발견된 취약점에 대해서는 즉각적인 조치를 취합니다.

③ 증거 보존 및 수집

휘발성 데이터 우선 수집: 시스템 메모리 덤프(RAM 내용), 현재 네트워크 연결 상태(netstat 등), 실행 중인 프로세스 목록, 로그인한 사용자 정보, 열려 있는 파일 목록 등 시스템이 종료되거나 시간이 지나면 사라지는 휘발성 정보를 최우선으로 수집합니다.

비휘발성 데이터 수집: 하드디스크, SSD 등 저장 장치의 전체 이미지를 원본



과 동일하게 복제(Disk Imaging)합니다. 또한, 시스템 로그(이벤트 로그, 보안 로그, 애플리케이션 로그, 웹 서버 로그, DB 로그 등), 보안 장비 로그, 네트워크 장비 로그 등 사고 분석에 필요한 모든 로그 파일을 수집합니다.

증거의 무결성 유지: 수집된 모든 디지털 증거에 대해 해시값(MD5, SHA256 등)을 계산하여 기록하고, 원본 데이터가 변경되지 않았음을 증명할 수 있도록 합니다. 증거 수집 과정(시간, 담당자, 사용 도구, 절차 등)을 상세히 문서화하고, 증거물의 획득부터 분석, 보관, 제출에 이르는 모든 과정을 추적할 수 있도록 연계 보관성(Chain of Custody)을 확보해야 합니다.

KISA 등 관계 기관에 침해사고를 신고하고 기술 지원을 요청할 경우, 분석을 위한 관련 자료 제출을 요구받을 수 있으므로 이에 대비해야 합니다.

2. 분석/대응

① 침해 원인 상세 분석

수집된 증거(시스템 로그, 네트워크 트래픽, 메모리 덤프, 디스크 이미지, 악성코드 샘플 등)를 정밀하게 분석하여 공격의 정확한 유입 경로, 악용된 보안 취약점, 공격자가 사용한 TTPs(Tactics, Techniques, and Procedures) 등을 구체적으로 식별합니다. 이를 위해 파일 시스템 분석, 네트워크 포렌식, 악성코드 정적/동적 분석 등의 전문적인 분석 기법이 활용될 수 있습니다. 필요한 경우, KISA의 침해사고 원인 분석 기술 지원 서비스를 활용할 수 있습니다. 이 단계의 목표는 공격의 근본 원인을 파악하고 시스템에서 모든 악성 요소(악성코드, 백도어, 불법 계정 등)를 완전히 제거(Eradication)하는 것입니다.

② 피해 범위 식별 및 시스템 복구 전략

상세 분석을 통해 공격으로 인해 영향을 받은 모든 시스템, 데이터, 사용자 계정 등의 전체 피해 범위를 최종적으로 확정합니다. 이후, 사전에 마련된 백업 및 복구 절차에 따라 시스템을 복구합니다. 이때, 백업 데이터의 유효성과 안전성을 반드시 검증하고, 공격 이전의 가장 안전한 시점으로 시스템을 복원해야 합니다. 복구된 시스템은 즉시 서비스에 투입하기 전에 보안 설정을 강화



하고, 충분한 모니터링을 거쳐 안정성을 확인한 후 서비스를 재개해야 합니다.

③ 취약점 제거 및 보안 설정 강화

공격에 직접적으로 악용된 보안 취약점은 즉시 패치하거나 관련 설정을 변경하여 제거해야 합니다. 더 나아가, 이번 침해사고를 계기로 서버 전반의 보안 설정을 점검하고 강화하는 하드닝(Hardening) 작업을 수행해야 합니다. 여기에는 불필요한 서비스 및 계정 제거, 패스워드 정책 강화, 접근 통제 규칙 재정비, 시스템 및 애플리케이션 로그 설정 강화 등이 포함됩니다. KISA에서 제공하는 각종 서버 보안 가이드라인을 참고하여 조치할 수 있습니다.

④ 재발 방지 대책 수립 및 이행

침해사고 대응의 마지막 단계는 유사한 사고의 재발을 방지하기 위한 근본적인 대책을 수립하고 이를 지속적으로 이행하는 것입니다. 이를 위해 침해사고의 탐지부터 복구까지 전 과정을 검토하여 미흡했던 부분이나 개선이 필요한 사항을 도출합니다. 도출된 개선점은 보안 정책, 내부 지침, 시스템 설정, 보안 솔루션 운영 방식, 임직원 보안 교육 내용 등에 반영되어야 합니다. 또한, 식별된 새로운 위협 정보나 공격 패턴 등은 내부 관련 부서 및 KISA 등 유관기관과 공유하여 향후 유사 침해사고 예방에 활용될 수 있도록 합니다.

3. 참고사항

① 침해사고 신고 및 피해지원

- 웹 서버 등 해킹 공격으로 확인되었거나 의심되는 경우 KISA 등 유관기관에 신고를 하면, 전문가들의 지원을 받아 원인을 분석하고 지원이 가능합니다.

※ 근거법령 : 정보통신망 이용촉진 및 정보보호 등에 관한 법률
제48조의 3(침해사고의 신고 등)

<신고방법>